

Phishing and Social Engineering

Phishing is a type of cyberattack in which attackers impersonate legitimate organizations or individuals in order to trick victims into revealing sensitive information, such as passwords, credit card numbers, or personal identification details. Phishing attacks are most commonly delivered via email, where a message may appear to come from a trusted source, such as a bank or well-known company, and often creates a sense of urgency to pressure the recipient into clicking a malicious link or providing information without careful consideration. Spear phishing is a more targeted variant, in which attackers research a specific individual or organization to craft a highly personalized and convincing message, significantly increasing the likelihood of success. Whaling refers to phishing attacks specifically targeting high-profile individuals, such as executives, given the potentially greater rewards for attackers. Social engineering more broadly encompasses a range of psychological manipulation techniques used by attackers to deceive individuals into breaking normal security procedures. This can include pretexting, where an attacker fabricates a scenario to obtain information, or baiting, where a tempting offer, such as a free download, is used to lure victims into compromising their systems. Defending against phishing and social engineering requires a combination of technical measures, such as email filtering systems that detect suspicious messages, and human awareness training, since even the most sophisticated technical defenses can be undermined by an employee who unknowingly falls victim to a well-crafted deception. Organizations increasingly conduct simulated phishing exercises to train employees to recognize and report suspicious messages before real damage occurs.